COMPTIA SECURITY+ SY0-701 DOMÍNIO 3 · ARQUITETURA DE SEGURANÇA (18%)

Security+ 3.1 · Cloud Infrastructures

Mestre CyberSec · **Aula 3.1 — Cloud Infrastructures** (9:56) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Nuvem: IaaS (EC2 — tu cuida do SO pra cima); PaaS (heroku/AWS Beanstalk — plataforma pronta); SaaS (Gmail — tudo pronto). Serverless/FaaS (Lambda: código sobe na chamada, paga por execução). IaC (Infrastructure as Code — Terraform, CloudFormation — infra VERSÃO-EDITÁVEL). Defesa:

💡 Highlights que a prova CompTIA cobra

- IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider
- Serverless (Lambda): sem servidor — paga execução
- IaC (Terraform): infra como código — versionada audível

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'cloud model where user manages the OS and above' = IaaS
- "runs code without managing servers" = serverless/FaaS

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 3.1 — Cloud Infrastructures)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Infraestrutura como Serviço (IaaS)
Modelo de nuvem em que o provedor fornece hardware, armazenamento e rede, mas o cliente é responsável pelo sistema operacional, middleware, runtime, dados e aplicações. O exemplo canônico é o EC2.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'user manages the OS and above' → IaaS. Se a questão mencionar controle do SO, patch do SO, ou instalação de hypervisor pelo cliente, é IaaS. Não confunda com PaaS.*

• Plataforma como Serviço (PaaS)
Modelo de nuvem em que o provedor fornece SO, middleware e runtime; o cliente gerencia apenas o código da aplicação e os dados. Exemplos: Heroku e AWS Elastic Beanstalk.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'customer only manages the application and data' → PaaS. Se a questão mostra desenvolvedores focando só em código sem se preocupar com servidor, é PaaS.*

• Software como Serviço (SaaS)
Modelo em que o provedor entrega uma aplicação totalmente pronta via web; o cliente apenas usa o software e faz configurações no nível de usuário. Exemplos clássicos: Gmail e Microsoft 365.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'provider manages everything, user just logs in' → SaaS. Se a questão fala em 'office suite', email corporativo ou CRM na nuvem, é SaaS.*

• Serverless / Função como Serviço (FaaS)
Modelo de execução em que o cliente sobe funções individuais que rodam sob demanda em resposta a eventos; os servidores são totalmente gerenciados pelo provedor e o pagamento é por execução. AWS Lambda é o principal exemplo.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'runs code without provisioning or managing servers' ou 'payments persist beyond execution' → Serverless/FaaS. Não confunda com IaaS (há servidor, você só não gerencia).*

• Infraestrutura como Código (IaC)
Prática de definir e provisionar recursos de nuvem por meio de arquivos de configuração declarativos ou scripts, permitindo que a infraestrutura seja versionada, auditável e reproduzível. Terraform e AWS CloudFormation são as ferramentas líderes.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'versioned, auditable infrastructure' ou 'Terraform/CloudFormation' → IaC. A pegadinha é confundir com scripting tradicional: IaC é declarativo e idempotente.*

• Modelos de Implantação em Nuvem (Pública, Privada, Híbrida, Comunitária) (N/A)

Classificação dos ambientes de nuvem por propriedade e acesso: Pública (aberta a qualquer pessoa, infraestrutura compartilhada do provedor), Híbrida (mistura on-premises + colab pública com orquestração) e Comunitária (compartilhada por organizações com interesse comum, ex.: governo ou saúde).

⚠️ ***Armadilha CompTIA:*** *Gatilhos: 'on-premises + cloud working together with orchestration' → Hybrid. 'Cloud shared by orgs with same regulatory requirement' → Community. Cuidado para não marcar Public quando a questão cita 'dedicated resources' (seria Private).*

• VM Escape

Exploração de segurança em que um atacante sai do sistema operacional convidado virtualizado e interage diretamente com o hypervisor ou com outras VMs no mesmo host, comprometendo o isolamento que a virtualização deveria prover.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'attacker breaks out of a virtual machine' ou 'attacks the hypervisor from a guest' → VM Escape. Sempre relacione com falha no isolamento de VMs; a defesa exige manter o hypervisor atualizado.*

• Contêinerização (N/A)

Técnica de virtualização leve que empacota uma aplicação com suas bibliotecas e dependências em uma instância isolada de espaço de usuário, compartilhando o kernel do SO hospedeiro; Docker e Kubernetes (k8s) são as tecnologias dominantes.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'lightweight isolation, shared kernel, faster than VMs' → Containers. Atenção na pegadinha: containers compartilham o kernel (diferente de VM, que tem SO completo), então um exploit no kernel afeta todos os contêineres.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Modelos de Serviço em Nuvem: IaaS vs. PaaS vs. SaaS

🏠 **Analogia Intuitiva:** Pense em moradia e refeição: IaaS é alugar um terreno vazio ou galpão cru onde você constrói as paredes, coloca a fiação e instala os móveis (você gerencia SO, patches e aplicativos). PaaS é alugar uma cozinha industrial mobiliada com fogão e gás encanado: a estrutura básica está pronta, você só entra com a sua receita e os ingredientes (você só gerencia o código e os dados da aplicação). SaaS é pedir um prato pronto pelo iFood: você não sabe quem cozinhou nem limpou o fogão, apenas consome o serviço pelo navegador ou app.

🔍 **Causa Raiz / Por que foi criado:** O modelo de Responsabilidade Compartilhada (Shared Responsibility Model) dita quem é legalmente e tecnicamente responsável por falhas de segurança. No IaaS, a causa raiz de invasões quase sempre é o cliente esquecendo de atualizar o SO ou deixando portas abertas no Security Group; no SaaS, a responsabilidade do cliente se limita ao controle de acesso (IAM) e proteção de credenciais.

🛡️ **Visão do Auditor de GRC:** Revisar as matrizes de responsabilidade compartilhada (RACI) do provedor de nuvem (AWS/Azure/GCP); verificar conformidade de patches de SO em instâncias EC2/VMs para IaaS; auditar permissões de SSO, MFA e DLP para aplicações SaaS.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'customer is responsible for OS updates, patch management, and network firewall rules'. Resposta: IaaS (Infrastructure as a Service). Se disser 'customer only manages code and data, provider handles OS and runtime', a resposta é PaaS.

📌 Computação sem Servidor: Serverless / FaaS (Function as a Service)

🏠 **Analogia Intuitiva:** É como uma lâmpada com sensor de presença no corredor. Ela não fica acesa 24 horas gastando energia; no momento em que alguém passa (um evento/gatilho acontece), ela acende instantaneamente por 10 segundos, faz o trabalho e se apaga. Você só paga pelos segundos em que a luz ficou ligada.

🔍 **Causa Raiz / Por que foi criado:** Servidores tradicionais ficam ociosos desperdiçando dinheiro e criando superfícies persistentes de ataque. O Serverless executa funções isoladas e efêmeras sob demanda. Por outro lado, como são baseadas em eventos, se as permissões de execução (IAM roles) forem muito amplas ou o código tiver vulnerabilidade de injeção, o atacante pode escalar privilégios dentro do ecossistema de nuvem.

🛡️ **Visão do Auditor de GRC:** Garantir a aplicação do Princípio do Menor Privilégio em Execution Roles das funções (Lambda/Cloud Functions); auditar timeouts de execução e limites de concorrência para evitar ataques de esgotamento de orçamento (EDoS).

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'executes microservice code only in response to events or HTTP requests, with no underlying server to manage or patch'. Resposta: Serverless / FaaS (Function as a Service).

📌 Modelos de Implantação de Nuvem: Pública, Privada, Comunitária e Híbrida

🏠 **Analogia Intuitiva:** Nuvem Pública é como um condomínio residencial aberto a qualquer comprador, onde cada um tranca sua porta mas divide a área de lazer. Nuvem Privada é uma mansão murada exclusiva para uma única família. Nuvem Comunitária é uma vila fechada exclusiva para médicos de um mesmo hospital que dividem os custos de portaria. Nuvem Híbrida é morar na mansão particular mas alugar flats na cidade quando parentes vêm visitar em datas comemorativas.

🔍 **Causa Raiz / Por que foi criado:** Equilíbrio entre custo, elasticidade e conformidade regulatória severa (como HIPAA, PCI-DSS ou dados de inteligência militar). Empresas que mantêm dados ultrassensíveis em data center local on-premises e usam nuvem pública para picos de processamento web adotam o modelo híbrido.

🛡️ **Visão do Auditor de GRC:** Avaliar acordos de custódia e soberania de dados (Data Sovereignty); verificar isolamento de multi-inquilinos (multi-tenancy) e certificações de conformidade governamental (FedRAMP, ISO 27017, SOC 2).

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'several hospitals share cloud infrastructure to comply with health regulations and split maintenance costs'. Resposta: Community Cloud. 'Organization connects on-premises data center with public cloud provider' -> Hybrid Cloud.

📌 Computação de Borda e Computação em Névoa: Edge Computing vs. Fog Computing

🏠 **Analogia Intuitiva:** Imagine um carro autônomo na rodovia: se ele precisar frear porque um pedestre atravessou, ele não pode enviar o vídeo para a nuvem nos EUA e esperar a resposta voltar — ele bateria o carro. A decisão de pisar no freio precisa ser processada imediatamente pelo microcomputador dentro do próprio carro: isso é Edge Computing. Já a Fog Computing é a central regional do bairro ou a antena 5G da esquina que reúne os dados de 50 carros próximos para sincronizar o semáforo antes de enviar o resumo para a nuvem central.

🔍 **Causa Raiz / Por que foi criado:** A latência da velocidade da luz e os limites de largura de banda de telecomunicações impedem decisões em frações de milissegundos na nuvem central. O processamento na borda reduz o tempo de resposta a quase zero e economiza banda de rede.

🛡️ **Visão do Auditor de GRC:** Avaliar segurança física dos dispositivos de borda expostos a adulteração (Tamper Resistance); verificar criptografia de armazenamento local (FDE) e canais TLS seguros para sincronização de telemetria.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'autonomous sensors require ultra-low latency processing directly at the point of data generation to eliminate network lag'. Resposta: Edge Computing. 'Intermediary processing layer between local IoT sensors and central cloud' -> Fog Computing.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
O cliente precisa gerenciar o sistema operacional, antivírus e regras de firewall em instâncias virtuais alugadas	**IaaS (Infrastructure as a Service)**
Desenvolvedores enviam código de aplicação sem gerenciar sistema operacional, banco ou infraestrutura física	**PaaS (Platform as a Service)**
Usuários acessam software de e-mail e produtividade pronto pelo navegador, sem acesso a servidores ou código	**SaaS (Software as a Service)**
Trechos de código que rodam exclusivamente mediante gatilhos de eventos e cobram apenas pelos milissegundos de execução	**Serverless / FaaS (Function as a Service)**
Empresas do mesmo ramo de saúde compartilham uma infraestrutura para reduzir custos e cumprir leis comuns	**Nuvem Comunitária (Community Cloud)**
Processamento de dados em tempo real realizado no próprio sensor ou dispositivo para eliminar a latência de envio à nuvem	**Computação de Borda (Edge Computing)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa aluga máquinas virtuais, armazenamento em bloco e rede virtual de um provedor de nuvem pública. O provedor gerencia os hosts físicos e o hypervisor, enquanto os administradores da empresa são responsáveis por aplicar patches nos sistemas operacionais convidados, instalar middleware e configurar grupos de segurança. Qual modelo de serviço de nuvem isso descreve?

A) IaaS

B) PaaS

C) SaaS

D) FaaS

QUESTÃO 2 · CENÁRIO DE EXAME

Uma equipe de desenvolvimento deseja implantar uma aplicação web Java sem gerenciar o sistema operacional, atualizações de runtime ou balanceamento de carga. O provedor fornece o runtime, middleware e escalabilidade, mas a equipe continua responsável pelo código e configuração da aplicação. Qual modelo está sendo usado?

A) IaaS

B) PaaS

C) SaaS

D) Serverless/FaaS

QUESTÃO 3 · CENÁRIO DE EXAME

Uma organização adota um conjunto de e-mail e produtividade em nuvem. O provedor gerencia os data centers, atualizações da aplicação e disponibilidade do serviço, enquanto a organização gerencia apenas contas de usuários, permissões de acesso e seus próprios dados. Qual modelo de serviço de nuvem está em uso?

A) IaaS

B) PaaS

C) SaaS

D) FaaS

QUESTÃO 4 · CENÁRIO DE EXAME

Uma startup envia código de processamento de imagens que é executado apenas quando novas fotos são adicionadas ao armazenamento de objetos. O provedor de nuvem provisiona o runtime sob demanda, escala automaticamente por evento e cobra com base no tempo de execução e nas requisições. A startup não gerencia servidores nem contêineres. Qual modelo melhor corresponde a essa implantação?

A) IaaS

B) PaaS

C) SaaS

D) Serverless/FaaS

QUESTÃO 5 · CENÁRIO DE EXAME

Uma equipe de engenharia de nuvem armazena definições Terraform em um repositório Git e as implanta por meio de um pipeline CI/CD. Durante uma revisão, um auditor encontra um commit que define um bucket de armazenamento de produção com leitura pública. Qual controle impediria mais efetivamente que definições de infraestrutura inseguras semelhantes chegassem à produção?

A) Executar análise estática automatizada de IaC e verificações de policy-as-code no pipeline CI/CD.

B) Exigir autenticação multifator para a conta root da nuvem.

C) Habilitar criptografia padrão em todos os buckets de armazenamento.

D) Implantar um bastion host para acesso SSH administrativo.

QUESTÃO 6 · CENÁRIO DE EXAME

Vários hospitais com requisitos regulatórios semelhantes formam um consórcio para compartilhar um ambiente de nuvem para um aplicativo comum de registros de pacientes. A infraestrutura é provisionada para uso exclusivo do consórcio e governada pelas organizações participantes, não pelo público em geral. Qual modelo de implantação é este?

A) Nuvem pública

B) Nuvem privada

C) Nuvem híbrida

D) Nuvem comunitária

QUESTÃO 7 · CENÁRIO DE EXAME

Um varejista mantém sistemas de processamento de pagamentos em seu próprio data center por conformidade, mas usa uma nuvem pública para o front-end de e-commerce e análises sazonais. Os dois ambientes são conectados por VPN segura e compartilham gerenciamento de identidade centralizado. Qual modelo de implantação de nuvem é descrito?

A) Pública

B) Privada

C) Híbrida

D) Comunitária

QUESTÃO 8 · CENÁRIO DE EXAME

Um atacante compromete uma máquina virtual convidada em um ambiente de nuvem multilocatário e explora uma vulnerabilidade do hypervisor para ler memória e acessar VMs de outros clientes em execução no mesmo host físico. Como esse ataque é chamado?

A) Escape de contêiner

B) Escape de VM

C) Exfiltração de dados em nuvem

D) Negação de serviço de hypervisor

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa executa microsserviços em contêineres em um cluster Kubernetes compartilhado. Após uma aplicação web vulnerável ser comprometida dentro de um contêiner, o atacante tenta escapar e afetar o nó subjacente e outras cargas de trabalho. Qual controle reduz mais diretamente o impacto desse tipo de ataque?

A) Executar contêineres como non-root, remover capacidades Linux desnecessárias e aplicar perfis seccomp/AppArmor.

B) Habilitar um firewall de aplicação web na frente do controlador de ingress.

C) Criptografar volumes persistentes com uma chave gerenciada pelo cliente.

D) Mover o cluster para uma nuvem privada de locatário único sem alterar as configurações dos contêineres.

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa assina uma plataforma SaaS de gestão de relacionamento com o cliente. O provedor é responsável pelo código da aplicação, servidores e segurança física do data center. Qual responsabilidade de segurança permanece principalmente com o cliente?

A) Aplicar patches nos sistemas operacionais dos servidores da aplicação de CRM

B) Manter o hypervisor que hospeda a aplicação de CRM

C) Configurar acesso de usuários, funções e autenticação multifator

D) Proteger o perímetro físico do data center do provedor

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — IaaS

IaaS fornece computação, armazenamento e rede virtualizados. O cliente gerencia o SO convidado, middleware, aplicações e alguns controles de segurança, enquanto o provedor gerencia a infraestrutura física e o hypervisor. PaaS ocultaria o gerenciamento do SO e runtime; SaaS forneceria uma aplicação completa; FaaS executaria código orientado a eventos sem gerenciamento de servidores.

Questão 2: Alternativa B — PaaS

PaaS fornece uma plataforma gerenciada para implantar aplicações. O provedor gerencia o SO, runtime, middleware e escalabilidade, enquanto o cliente gerencia o código e a configuração da aplicação. IaaS exigiria gerenciamento do SO; SaaS é uma aplicação completa; FaaS normalmente é execução de funções orientada a eventos, não uma plataforma gerenciada de aplicações.

Questão 3: Alternativa C — SaaS

SaaS entrega uma aplicação completa gerenciada pelo provedor. O cliente não gerencia os servidores, SO, runtime ou código da aplicação subjacente, mas continua responsável por identidade, controle de acesso, tratamento de dados e configuração de permissões de usuários.

Questão 4: Alternativa D — Serverless/FaaS

Serverless/FaaS executa código em resposta a eventos sem exigir que o cliente gerencie servidores ou contêineres. O provedor cuida do provisionamento, escalabilidade e disponibilidade do runtime, e a cobrança normalmente é baseada em invocações e duração da execução. IaaS e PaaS exigem mais gerenciamento de infraestrutura ou plataforma pelo cliente, enquanto SaaS é uma aplicação completa.

Questão 5: Alternativa A — Executar análise estática automatizada de IaC e verificações de policy-as-code no pipeline CI/CD.

Infraestrutura como Código deve ser validada antes da implantação. Análise estática e verificações de policy-as-code podem detectar definições Terraform inseguras, como buckets públicos, e bloqueá-las no pipeline CI/CD. MFA protege contas, mas não evita configurações incorretas de IaC. Criptografia não impede exposição pública, e um bastion host não tem relação com permissões de buckets de armazenamento.

Questão 6: Alternativa D — Nuvem comunitária

Uma nuvem comunitária é compartilhada por múltiplas organizações com interesses, necessidades de conformidade ou missões comuns. Ela não é aberta ao público geral como uma nuvem pública, não é dedicada a uma única organização como uma nuvem privada e não é uma mistura de local e nuvem pública como uma nuvem híbrida.

Questão 7: Alternativa C — Híbrida

Uma nuvem híbrida combina infraestrutura privada ou local com serviços de nuvem pública. O varejista mantém sistemas de pagamento sensíveis localmente enquanto usa nuvem pública para outras cargas de trabalho, integrando-os com conectividade segura e identidade centralizada.

Questão 8: Alternativa B — Escape de VM

Um escape de VM ocorre quando um atacante sai de uma máquina virtual convidada e compromete o hypervisor ou outras VMs no mesmo host. Escape de contêiner se aplica a contêineres, não a hypervisors; exfiltração de dados é um possível impacto; negação de serviço não descreve o acesso a outras VMs.

Questão 9: Alternativa A — Executar contêineres como non-root, remover capacidades Linux desnecessárias e aplicar perfis seccomp/AppArmor.

O hardening de contêineres reduz a capacidade de escape ou de afetar o host. Executar como non-root, remover capacidades e aplicar perfis seccomp/AppArmor limita os privilégios disponíveis após o comprometimento. Um WAF pode bloquear alguns ataques web, mas não impede diretamente o escape de contêiner. Criptografia protege dados em repouso, e uma nuvem privada sozinha não corrige configurações inseguras de contêiner.

Questão 10: Alternativa C — Configurar acesso de usuários, funções e autenticação multifator

Em SaaS, o provedor gerencia a aplicação, sistemas operacionais, servidores, hypervisor e infraestrutura física. O cliente continua responsável por gerenciar usuários, permissões de acesso, funções, configurações de autenticação como MFA e os dados que insere no serviço.